Cyber Security

Module 2: Cyber Security Foundations

Exam-Oriented Study Notes

Course Faculty: **Prof. Basabdatta Chakraborty**

Compiled by **Amitendu** and **Claude**

BCA, MAKAUT

Contents

1 Cyber Security: Definition **2**
1.1 Scope (Domains) . . . 2
1.2 Common Threats . . . 2
1.3 Basic Terms . . . 2

2 Security Triad (CIA) **3**
2.1 Related Concepts . . . 3

3 Hacking and Ethical Hacking **4**
3.1 Hacking vs Ethical Hacking . . . 4
3.2 Principles of Ethical Hacking . . . 4
3.3 Benefits and Limitations of Ethical Hacking . . . 4

4 Types of Hackers **5**

5 Phases of Hacking **5**
5.1 Phase 1: Reconnaissance (Footprinting) . . . 6
5.2 Phase 2: Scanning . . . 6
5.3 Phase 3: Gaining Access . . . 6
5.4 Phase 4: Maintaining Access . . . 6
5.5 Phase 5: Covering Tracks . . . 6
5.6 Summary and Defences . . . 7

6 Cryptography and Watermarking **7**
6.1 Cryptography . . . 7
6.2 Watermarking . . . 8
6.3 Cryptography vs Watermarking . . . 8
6.4 Uses . . . 8

7 Types of Cryptography **9**
7.1 Symmetric Key Cryptography . . . 9
7.2 Asymmetric Key Cryptography . . . 9
7.3 Hash Functions . . . 9
7.4 Classical Ciphers (Basic Idea) . . . 9
7.5 Hybrid Approach . . . 9

8 Symmetric vs Asymmetric Algorithms **10**
8.1 Comparison . . . 10
8.2 Common Symmetric Algorithms . . . 10
8.3 Common Asymmetric Algorithms . . . 10
8.4 Digital Signature (Idea) . . . 10

9 RSA Algorithm **11**
9.1 Step 1: Key Generation . . . 11
9.2 Step 2: Encryption and Decryption . . . 11
9.3 Worked Example . . . 11
9.4 Security of RSA . . . 12
9.5 Advantages and Disadvantages . . . 12

10 Quick Revision Sheet **13**

1 Cyber Security: Definition

Definition

Cyber security is the practice of protecting computers, networks, programs, devices and data from **unauthorised access, attack, damage or disruption**. It combines technology, processes and people to keep information safe in digital form.

1.1 Scope (Domains)

Domain	What it Protects
Network security	Network traffic, devices and communication links (firewalls, IDS/IPS, VPN)
Information (data) security	Data in storage and transit (encryption, access control, backup)
Application security	Software from flaws such as SQL injection and XSS
Endpoint security	Laptops, phones and servers (antivirus, patching, EDR)
Cloud security	Data and services hosted on cloud platforms
Operational security	Processes, policies and user permissions
End-user education	Awareness against phishing and social engineering

1.2 Common Threats

Malware (virus, worm, trojan, ransomware, spyware), phishing, denial of service, man-in-the-middle, SQL injection, password attacks, insider threats and social engineering.

1.3 Basic Terms

Term	Meaning
Asset	Anything of value to protect (data, systems, reputation)
Vulnerability	A weakness that can be exploited
Threat	A potential danger that may exploit a vulnerability
Exploit	A method or tool that takes advantage of a vulnerability
Risk	Likelihood of a threat exploiting a vulnerability $\times$ its impact
Attack	An actual attempt to harm an asset

Exam Tip

A good definition answer has three parts: *what is protected, from what, and the goal* (CIA). Add one or two examples for full marks.

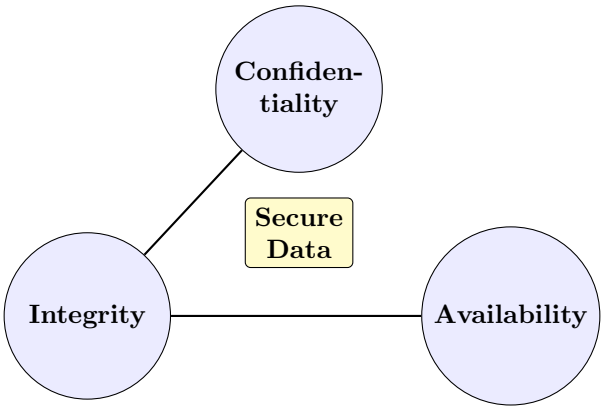
Practice Questions

Short Answer: (1) Define cyber security. (2) Differentiate threat, vulnerability and risk. (3) Name any four domains of cyber security.

Long Answer: (4) Explain the scope and importance of cyber security with examples.

2 Security Triad (CIA)

The **CIA triad** is the core model of information security. Every security control aims to protect at least one of its three goals.



Goal	Meaning	Controls	Attack Against It
Confidentiality	Only authorised people can read the data	Encryption, passwords, MFA, access control	Data breach, sniffing, phishing
Integrity	Data stays accurate and unaltered	Hashing, digital signatures, checksums, version control	Tampering, man-in-the-middle, malware
Availability	Systems and data are accessible when needed	Backups, redundancy, load balancing, DDoS protection	DoS/DDoS, ransomware, hardware failure

2.1 Related Concepts

- **Authentication:** proving identity (password, OTP, biometrics).
- **Authorisation:** deciding what an authenticated user may do.
- **Accounting:** logging user actions (together: **AAA**).
- **Non-repudiation:** a sender cannot deny sending a message (digital signatures).

Case Study: Ransomware Attack on a Hospital

Scenario: A city hospital stores patient records on a central server. An employee opens a phishing email; ransomware spreads and encrypts the records, and a copy of the data is also stolen.

CIA analysis:

- **Confidentiality violated:** stolen patient data may be leaked or sold.
- **Integrity at risk:** if attackers changed records (e.g. allergies or dosage), treatment decisions become unsafe.
- **Availability violated:** doctors cannot access records, so surgeries and emergency care are delayed.

Controls that would have helped:

- **C:** encrypt data, enforce MFA, role-based access.
- **I:** hashing and audit logs to detect tampering.
- **A:** offline and offsite **backups**, network segmentation, patching, and a tested incident response plan.

- **People:** phishing-awareness training.

Lesson: one attack can break all three goals, so defence must be layered (defence in depth).

Exam Tip

When asked for a case study, map the incident to **C, I and A separately**, then list preventive controls under each. Draw the triad diagram first.

Practice Questions

Short Answer: (1) What does CIA stand for? (2) Which goal does a DDoS attack target? (3) What is non-repudiation?
Long Answer: (4) Explain the CIA triad with examples and controls. (5) Analyse any real-world incident using the CIA triad.

3 Hacking and Ethical Hacking

Definitions

Hacking is gaining access to, or manipulating, a computer system or network by exploiting weaknesses. It is **illegal** when done without permission.
Ethical hacking is **authorised** testing of a system's security, using the same techniques as attackers, to find and fix weaknesses before criminals exploit them. It is also called **penetration testing**.

3.1 Hacking vs Ethical Hacking

Basis	Hacking (Malicious)	Ethical Hacking
Permission	No authorisation	Written authorisation from the owner
Intent	Theft, damage, profit, disruption	Improve security
Legality	Illegal	Legal, within agreed scope
Result	Data loss, financial harm	Report with vulnerabilities and fixes
Disclosure	Hidden	Findings reported confidentially to the owner

3.2 Principles of Ethical Hacking

Get written permission, stay within the agreed **scope**, respect privacy and confidentiality, do not damage systems or data, report all findings honestly, and follow the law (in India, the **Information Technology Act, 2000**, e.g. Sections 43 and 66, covers unauthorised access and hacking).

3.3 Benefits and Limitations of Ethical Hacking

Benefits	Limitations
Finds weaknesses before attackers do	Needs skilled, trusted professionals
Helps meet compliance requirements	Testing may disrupt services if done carelessly
Builds customer trust	Only covers the agreed scope and time
Reduces financial and reputational loss	Can be costly; results are a snapshot in time

Exam Tip

Stress the word **authorised**. The only real difference between a hacker and an ethical hacker is permission and intent. Mention penetration testing and the IT Act for extra marks.

Practice Questions

Short Answer: (1) Define ethical hacking. (2) Is penetration testing legal? Why? (3) Write two benefits of ethical hacking.

Long Answer: (4) Differentiate between hacking and ethical hacking. Explain its principles.

4 Types of Hackers

Hackers are commonly classified by **hat colour**, based on intent and legality.

Type	Description	Motive / Legality
White Hat	Security professionals who test systems with permission	Defend and improve security; legal
Black Hat	Break into systems without permission	Money, theft, damage; illegal
Grey Hat	Access systems without permission but without malicious intent, often reporting the flaw afterwards	Curiosity or reputation; still illegal because it lacks authorisation
Script Kiddie	Unskilled person who uses ready-made tools and scripts	Fun, showing off; illegal
Hacktivist	Hacks to promote a political or social cause	Ideology (e.g. defacing websites, DDoS); illegal
State-sponsored	Skilled teams funded by governments	Espionage, cyber warfare
Insider / Malicious Insider	Employee or contractor who abuses legitimate access	Revenge, money
Red / Blue / Purple Team	Red = attackers in a test, Blue = defenders, Purple = both cooperate	Authorised security exercises; legal

Remember

Grey hat is **not** ethical hacking: even with good intentions, accessing a system without permission is unlawful.

Exam Tip

A comparison table of White, Black and Grey hats is the most common 5-mark question. Always include *permission, intent, legality* and an example for each.

Practice Questions

Short Answer: (1) Who is a script kiddie? (2) What is a hacktivist? (3) Differentiate white hat and black hat hackers.

Long Answer: (4) Explain the different types of hackers with their motives.

5 Phases of Hacking

An attack (or a penetration test) follows five structured phases.



5.1 Phase 1: Reconnaissance (Footprinting)

Gathering as much information as possible about the target before attacking.

- **Passive:** no direct contact with the target; uses public sources such as WHOIS, DNS records, search engines, social media, job postings.
- **Active:** direct interaction, such as probing the target's servers or social engineering calls.
- **Information gained:** domain names, IP ranges, employee names and emails, technologies used.
- **Tools:** WHOIS, nslookup, Maltego, Google search operators, theHarvester.

5.2 Phase 2: Scanning

Using the information to find live hosts, **open ports**, running services and **vulnerabilities**.

- **Types:** port scanning, network scanning (which hosts are alive), vulnerability scanning.
- **Tools:** Nmap, Nessus, OpenVAS, Wireshark.

5.3 Phase 3: Gaining Access

Exploiting a discovered weakness to enter the system or network.

- **Methods:** password cracking, exploiting software bugs, phishing, SQL injection, misconfigurations.
- **Goal:** obtain a foothold and then raise privileges (privilege escalation) to admin or root.
- **Tools:** Metasploit, John the Ripper, Hydra.

5.4 Phase 4: Maintaining Access

Keeping access for future use without having to break in again.

- **Methods:** backdoors, trojans, rootkits, creating hidden user accounts, installing remote access tools.
- **Possible actions:** data theft, using the host as a **zombie** for botnets or to attack other systems.

5.5 Phase 5: Covering Tracks

Hiding evidence so the intrusion goes undetected.

- **Methods:** clearing or editing logs, hiding files, disabling auditing and alerts, altering timestamps.

5.6 Summary and Defences

Phase	Attacker Goal	Defence
Reconnaissance	Collect information	Limit public information, staff awareness, hide WHOIS details
Scanning	Find open ports and weaknesses	Firewalls, IDS/IPS, close unused ports, regular vulnerability scans
Gaining Access	Enter the system	Patching, strong passwords with MFA, input validation
Maintaining Access	Stay inside	Antivirus/EDR, monitoring, least privilege
Covering Tracks	Remove evidence	Centralised, protected logging (SIEM), file integrity monitoring

Ethical Hacker's View

An ethical hacker follows the same phases but with permission, and the final stage becomes **reporting**: documenting findings and recommended fixes instead of hiding traces.

Exam Tip

Always write the five phases in order, give **2–3 points and a tool for each**, and add the defence table. Remember the order with: ***R**eal **S**ecurity **G**ets **M**ore **C**omplicated.*

Practice Questions

Short Answer: (1) Differentiate passive and active reconnaissance. (2) Name two scanning tools. (3) What is privilege escalation?

Long Answer: (4) Explain the five phases of hacking in detail. (5) How can an organisation defend against each phase?

6 Cryptography and Watermarking

6.1 Cryptography

Definition

Cryptography is the science of securing information by converting readable data (**plaintext**) into unreadable form (**ciphertext**) using an algorithm and a **key**, so only the intended person can convert it back.

Key terms:

Term	Meaning
Plaintext	Original readable message
Ciphertext	Scrambled, unreadable message
Encryption	Plaintext → Ciphertext
Decryption	Ciphertext → Plaintext
Cipher / Algorithm	The mathematical method used
Key	Secret value that controls the algorithm
Cryptanalysis	Breaking ciphers without the key

Goals of cryptography: Confidentiality (hide content), **Integrity** (detect changes), **Authentication** (verify identity), **Non-repudiation** (sender cannot deny).

6.2 Watermarking

Definition

Digital watermarking is embedding hidden (or visible) information, such as an owner's ID or logo, into digital content like images, audio, video or documents. Unlike encryption, the content remains **viewable**; the mark proves ownership or origin.

Types of watermarks:

- **Visible:** logo or text clearly seen on the content (company logo on a video).
- **Invisible:** hidden in the data and detected only with software.
- **Robust:** survives compression, cropping and editing (used for copyright).
- **Fragile:** breaks if the content is altered (used to detect tampering).

6.3 Cryptography vs Watermarking

Basis	Cryptography	Watermarking
Purpose	Keep content secret	Prove ownership, detect copying or tampering
Content after process	Unreadable without the key	Remains usable and viewable
Protection after decryption	None; once decrypted it is unprotected	Mark stays with the content
Example	Encrypting a message	Hidden ID in a photograph

6.4 Uses

Cryptography	Watermarking
Secure web browsing (HTTPS/TLS)	Copyright protection of images, music and films
Online banking and UPI transactions	Tracing the source of pirated videos (each copy gets a unique mark)
Messaging apps with end-to-end encryption	Currency notes and certificates (anti-counterfeiting)
Digital signatures and certificates	Tamper detection of medical or legal images
Password storage (hashing), VPNs, disk encryption	Broadcast monitoring of advertisements

Related Idea: Steganography

Steganography hides the *existence* of a secret message inside another file (e.g. text inside an image). Cryptography hides the *meaning*; steganography hides the *presence*. Watermarking is a related technique, but its goal is ownership rather than secret communication.

Exam Tip

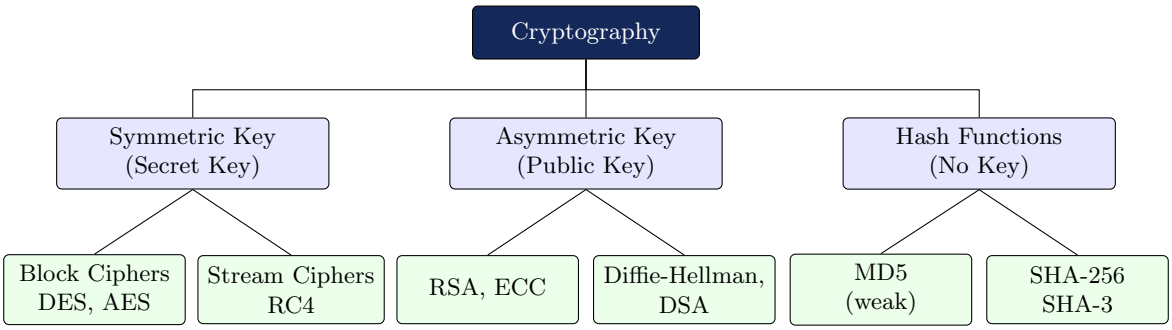
Examiners like the cryptography vs watermarking comparison and the list of real-world uses. Give at least three uses of each.

Practice Questions

Short Answer: (1) Define plaintext and ciphertext. (2) What is a digital watermark? (3) Differentiate robust and fragile watermarks.

Long Answer: (4) Explain cryptography and its goals with uses. (5) Compare cryptography with watermarking and steganography.

7 Types of Cryptography



7.1 Symmetric Key Cryptography

One shared secret key is used for both encryption and decryption. Fast, but the key must be shared securely (the **key distribution problem**).

7.2 Asymmetric Key Cryptography

Uses a **key pair**: a **public key** (shared openly) and a **private key** (kept secret). Data encrypted with one key is decrypted only with the other.

7.3 Hash Functions

A one-way function that converts any input into a fixed-length **digest**. It cannot be reversed. Used for **integrity** checks and password storage. Properties: deterministic, fast, one-way, collision resistant, and a tiny change in input changes the output completely (avalanche effect).

7.4 Classical Ciphers (Basic Idea)

- **Substitution:** replace letters. *Caesar cipher* with shift 3: HELLO → KHOOR.
- **Transposition:** rearrange the positions of letters without changing them.

Classical ciphers are easily broken today and are studied for understanding only.

7.5 Hybrid Approach

Real systems such as **TLS (HTTPS)** combine both: asymmetric cryptography safely exchanges a session key, then fast symmetric encryption protects the actual data.

Exam Tip

If the question says "types of cryptography", cover **symmetric, asymmetric and hashing** with a tree diagram. Mention the hybrid approach and give one algorithm for each.

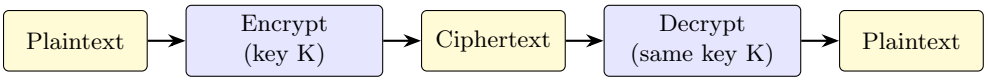
Practice Questions

Short Answer: (1) Name the three types of cryptography. (2) Why can a hash not be reversed? (3) Encrypt "CAT" using a Caesar cipher with shift 3.

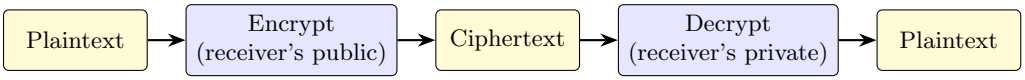
Long Answer: (4) Explain the types of cryptography with examples.

8 Symmetric vs Asymmetric Algorithms

Symmetric



Asymmetric



8.1 Comparison

Basis	Symmetric	Asymmetric
Keys	One shared secret key	Public and private key pair
Speed	Very fast	Slow (heavy mathematics)
Key length	128–256 bits	2048+ bits (RSA); 256 bits (ECC)
Key distribution	Difficult; secure channel needed	Easy; public key can be shared openly
Number of keys for n users	$\frac{n(n-1)}{2}$	$2n$
Best for	Encrypting large amounts of data	Key exchange, digital signatures, small data
Provides	Confidentiality	Confidentiality, authentication, non-repudiation
Algorithms	DES, 3DES, AES, Blowfish, RC4	RSA, ECC, ElGamal, DSA, Diffie-Hellman

8.2 Common Symmetric Algorithms

Algorithm	Key Size	Block Size	Remark
DES	56 bits	64 bits	16 rounds; now insecure (brute force)
3DES	112 / 168 bits	64 bits	DES applied three times; being phased out
AES	128, 192, 256 bits	128 bits	10, 12 or 14 rounds; current standard
Blowfish	32–448 bits	64 bits	Fast and flexible
RC4	40–2048 bits	Stream	Stream cipher; now considered weak

8.3 Common Asymmetric Algorithms

- **RSA:** encryption and digital signatures; based on the difficulty of factoring large numbers.
- **ECC (Elliptic Curve):** same security as RSA with much smaller keys; good for mobiles.
- **Diffie-Hellman:** key exchange only (agree on a shared secret over an open channel).
- **DSA:** digital signatures.

8.4 Digital Signature (Idea)

The sender **signs** (encrypts the hash of) the message with their **private key**; anyone can **verify** it with the sender's **public key**. This proves **authenticity, integrity and non-repudiation**.

Two Directions of Use

Confidentiality: encrypt with the receiver's *public* key; only the receiver's *private* key can decrypt.
Authentication / signature: sign with the sender's *private* key; anyone can verify with the sender's *public* key.

Exam Tip

Learn the formula $n(n-1)/2$ **vs** $2n$, as it is a favourite numerical. For 10 users: symmetric needs 45 keys, asymmetric needs 20 keys.

Practice Questions

Short Answer: (1) Why is asymmetric encryption slower? (2) Which algorithm is the current symmetric standard? (3) How many keys are needed for 20 users in each system?
Long Answer: (4) Differentiate symmetric and asymmetric cryptography with a diagram. (5) Explain the working of a digital signature.

9 RSA Algorithm

Overview

RSA (Rivest–Shamir–Adleman, 1977) is the most widely used **asymmetric** algorithm. Its security rests on the fact that **multiplying two large primes is easy, but factoring their product is extremely hard**.

9.1 Step 1: Key Generation

1. Choose two large distinct primes p and q.
2. Compute the modulus $n = p \times q$.
3. Compute Euler's totient $\varphi(n) = (p-1)(q-1)$.
4. Choose public exponent e such that $1 < e < \varphi(n)$ and $\gcd(e, \varphi(n)) = 1$.
5. Compute private exponent d such that $e \cdot d \equiv 1 \pmod{\varphi(n)}$.

Public key $= (e, n)$ **Private key** $= (d, n)$

9.2 Step 2: Encryption and Decryption

$$\text{Encryption: } C = M^e \bmod n$$
$$\text{Decryption: } M = C^d \bmod n$$

where $M < n$ is the plaintext (as a number) and C is the ciphertext.

9.3 Worked Example

Given: $p = 3$, $q = 11$, message $M = 4$.
Key generation:

- $n = 3 \times 11 = 33$
- $\varphi(n) = (3-1)(11-1) = 2 \times 10 = 20$

- Choose $e = 3$ (since $\gcd(3, 20) = 1$)
- Find d: $3d \equiv 1 \pmod{20}$. Try $d = 7$: $3 \times 7 = 21 = 20 + 1$ ✓ So $d = 7$.

Public key $= (3, 33)$, **Private key** $= (7, 33)$.

Encryption: $C = 4^3 \bmod 33 = 64 \bmod 33 = \mathbf{31}$

Decryption: $M = 31^7 \bmod 33$. Reduce step by step:

$$31^2 = 961 \equiv 4 \pmod{33}$$
$$31^4 \equiv 4^2 = 16 \pmod{33}$$
$$31^7 = 31^4 \cdot 31^2 \cdot 31 \equiv 16 \cdot 4 \cdot 31 = 1984 \equiv 4 \pmod{33}$$

So $M = \mathbf{4}$, the original message is recovered.

Digital signature with the same keys: sign $S = M^d \bmod n = 4^7 \bmod 33 = 16$. Verify: $S^e \bmod n = 16^3 \bmod 33 = 4096 \bmod 33 = 4 = M$ ✓

9.4 Security of RSA

- Strength depends on the difficulty of **factoring** n; real keys are **2048 bits or more**, since tiny primes like those above are trivially broken.
- Plain ("textbook") RSA is insecure; real systems add **padding** (e.g. OAEP).
- Never share the **private key** or reuse weak random primes.
- RSA is slow, so it is mainly used to **exchange symmetric keys** and to **sign** data.

9.5 Advantages and Disadvantages

Advantages	Disadvantages
No need to share a secret key beforehand	Much slower than symmetric algorithms
Supports encryption and digital signatures	Needs large keys and heavy computation
Well studied and widely supported (TLS, SSH, email)	Vulnerable to future quantum computers

Exam Tip

In RSA numericals, write the steps in order: $n \to \varphi(n) \to e \to d \to$ *encrypt* $\to$ *decrypt*. Show every modular reduction, because marks are given stepwise. Always verify that decryption returns M.

Practice Questions

Short Answer: (1) On what problem is RSA's security based? (2) Write the encryption and decryption formulas. (3) Why is padding needed?

Numerical: (4) Using $p = 5$, $q = 11$, $e = 3$, find n, $\varphi(n)$, d, and encrypt $M = 9$. (5) Verify your answer by decrypting.

Long Answer: (6) Explain the RSA algorithm with key generation, encryption, decryption and an example.

10 Quick Revision Sheet

Topic	**Remember**
Cyber security	Protecting systems, networks and data from attack
CIA triad	Confidentiality, Integrity, Availability
Ethical hacking	Authorised, legal, finds weaknesses; also called penetration testing
Hat types	White = legal; Black = malicious; Grey = no permission but no bad intent
5 phases	Reconnaissance → Scanning → Gaining Access → Maintaining Access → Covering Tracks
Cryptography	Hides content using keys; watermarking proves ownership
Types	Symmetric, Asymmetric, Hash
Symmetric / Asymmetric	1 key, fast, AES / 2 keys, slow, RSA
Keys for n users	$n(n-1)/2$ vs $2n$
RSA formulas	$n = pq$, $\varphi = (p-1)(q-1)$, $ed \equiv 1 \pmod{\varphi}$, $C = M^e \bmod n$, $M = C^d \bmod n$
Hybrid use	RSA exchanges key, AES encrypts data (TLS)